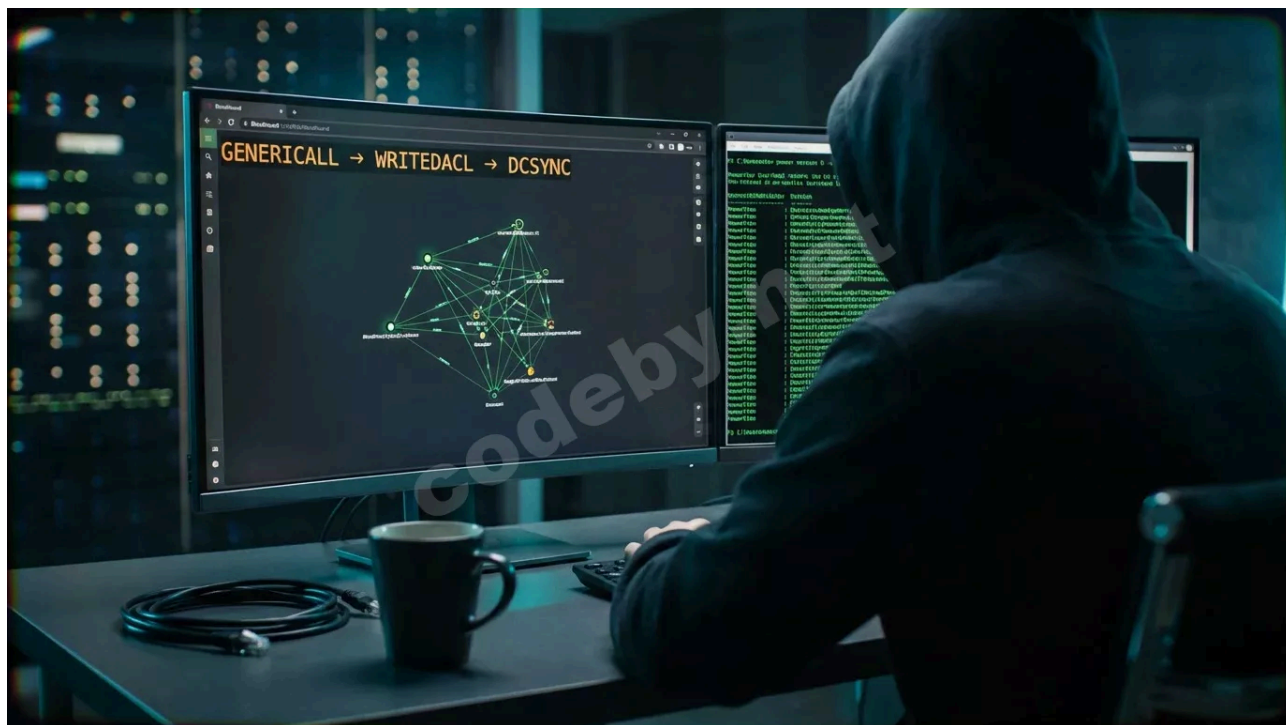


Статья Privilege Escalation в Active Directory: ACL-атаки, делегирование и цепочки от GenericAll до DCSync

 codeby.net/threads/privilege-escalation-v-active-directory-acl-ataki-delegirovaniye-i-tsepochki-ot-genericall-do-dcsync.92729

April 20, 2026

[Добавить закладку](#)



Закрепился в домене под рядовым пользователем - и что дальше? Брутфорс паролей, эксплуатация CVE - пути очевидные. Но самые жирные цепочки privilege escalation в Active Directory идут через ACL-мисконфигурации и злоупотребление делегированием Kerberos - два вектора, которые я подробно вписал в [общий гайд по пентесту Active Directory](#) среди прочих техник от разведки до Domain Admin. Эти векторы не требуют zero-day, не генерируют аномальный трафик и используют штатные механизмы AD ровно так, как они задуманы - просто не для тех целей. Красота в том, что ты не ломаешь систему, а пользуешься ею «по инструкции».

Здесь разберу конкретные ACL-права, которые превращают обычного доменного пользователя в Domain Admin, покажу цепочки эскалации через GenericAll, WriteDACL и WriteOwner, объясню, почему Resource-Based Constrained Delegation - полноценный вектор компрометации, и дам практическое руководство по эксплуатации каждого шага.

Как устроены ACL в Active Directory и почему они - золотая жила для атакующего

Каждый объект в AD - пользователь, группа, компьютер, OU - защищён списком управления доступом (DACL). DACL состоит из записей Access Control Entry (ACE), каждая из которых определяет: какой принципал (trustee) какие действия может выполнять над объектом. Принципал идентифицируется по SID, действие - по набору битовых флагов: GenericAll, WriteProperty, WriteDACL, WriteOwner и другие.

Проблема в том, что в реальных доменах ACL копятся годами. Helpdesk получает право сбрасывать пароли, но scope не ограничен Tier-2 аккаунтами. Сервисная учётка, создавшая компьютерный объект, сохраняет над ним полный контроль навсегда. Подрядчик ушёл - а его ACE на OU с серверами осталась. По данным Semperis, именно такие legacy-конфигурации создают ACL-пути, которые BloodHound визуализирует как прямые дороги до Domain Admin.

На каждом engagement я вижу одно и то же: домену 10+ лет, три поколения админов сменилось, а ACL - как геологические слои. Копнёшь - и найдёшь артефакт эпохи Windows Server 2003.

Для атакующего критичны не все ACE, а конкретный набор опасных прав. Разберу каждое.

Опасные ACL-права: GenericAll, WriteDACL, WriteOwner и другие

GenericAll - полный контроль над объектом

GenericAll на пользователе - это карт-бланш: сброс пароля, установка SPN для Kerberoasting (T1558.003, Credential Access), запись в msDS-KeyCredentialLink для Shadow Credentials или изменение любого атрибута. На группе - добавить себя в неё. На компьютере - настроить Resource-Based Constrained Delegation.

Классический сценарий с реального engagement: пользователь JSMITH состоит в группе TIER2 Helpdesk, у которой GenericAll на привилегированного пользователя RPERRY. RPERRY - член Windows Administrators, а эта группа может сбросить пароль учётки Azure AD Sync. У той учётки - права репликации AD. Три ACL-хопа - и вот тебе DCSync (T1003.006, Credential Access). Praetorian описывает это как один из самых частых паттернов, и я с ними согласен: видел подобное раз пять за последний год.

WriteDACL - право переписать правила игры

WriteDACL позволяет редактировать DACL объекта - добавлять новые ACE. Имея WriteDACL на объекте домена (DC), атакующий добавляет себе DS-Replication-Get-Changes и DS-Replication-Get-Changes-All, после чего выполняет DCSync. На группе - добавляет себе GenericAll и вписывает себя в Domain Admins.

Почему WriteDACL опаснее WriteOwner в большинстве сценариев? WriteOwner позволяет стать владельцем объекта, а владелец может модифицировать DACL. Но это двухшаговая операция: сначала Set-DomainObjectOwner, затем Add-DomainObjectAcl. WriteDACL даёт результат за один шаг. На практике разница невелика - оба права ведут к полному контролю. Но WriteDACL оставляет меньше следов: смена владельца генерирует отдельное событие аудита (Event ID 4662 с изменением Owner), а прямая правка DACL - нет.

ForceChangePassword и WriteProperty

ForceChangePassword - сброс пароля без знания текущего. Грубо, зато работает.

WriteProperty на конкретные атрибуты - тоньше: запись в servicePrincipalName открывает Targeted Kerberoasting, запись в msDS-AllowedToActOnBehalfOfOtherIdentity - RBCD-атаку, запись в msDS-KeyCredentialLink - Shadow Credentials.

Каждое из этих прав маппится на технику [Account Manipulation](#) (T1098, Persistence / Privilege Escalation) по MITRE ATT&CK.

[BloodHound и ACL-пути атак: от разведки до цепочки эскалации](#)

BloodHound - основной инструмент для построения ACL-путей атак в домене. Стандартные запросы «Shortest Path to Domain Admins» находят очевидные маршруты, но в крупных доменах самое вкусное скрыто в кастомных Cypher-запросах.

Для поиска объектов с WriteDACL на домен (ключевой путь к DCSync) - запрос к Neo4j:

```
MATCH p=(n)-[:WriteDacl]->(m:Domain)
WHERE NOT n.name STARTS WITH 'DOMAIN ADMINS'
RETURN p
```

Запрос отсекает легитимные пути от Domain Admins и показывает неожиданных принципалов с WriteDACL на объект домена. На одном из проектов я так обнаружил, что сервисная учётка системы мониторинга имела WriteDACL на корневой домен - админ когда-то делегировал ей права для чтения атрибутов, но промахнулся с score. Классика жанра.

Для поиска цепочек через GenericAll стоит строить запросы с переменной глубиной: `MATCH p=shortestPath((n:User {name:'JSMITH@CONTOSO.LOCAL'}) - [r:GenericAll|WriteDacl|WriteOwner|ForceChangePassword[I]1..5] -> (m:Group {name:'DOMAIN ADMIN@CONTOSO.LOCAL'})) RETURN p`. Параметр `[/I]1..5` задаёт максимум хопов - увеличивайте для больших графов, но будьте готовы ждать.

Злоупотребление делегированием Kerberos

Делегирование Kerberos - механизм, позволяющий сервису обращаться к другим ресурсам от имени пользователя. Три типа делегирования - три разных вектора атаки.

Unconstrained Delegation

Компьютер с unconstrained delegation кеширует TGT всех пользователей, которые к нему обращаются. Контроль над таким хостом = все TGT из памяти (включая привилегированные учётки) = доступ куда угодно. В связке с принуждением к аутентификации (PrinterBug через MS-RPRN) атакующий вынуждает контроллер домена отправить свой TGT на скомпрометированный хост. Прямой путь к компрометации домена - без единого эксплойта.

Найти такие хосты можно через PowerView: `Get-DomainComputer -Unconstrained` или через BloodHound, где они маркируются соответствующим свойством.

Constrained Delegation и S4U2Proxy

Constrained delegation ограничивает перечень сервисов, к которым учётка может обращаться от имени пользователя. Список лежит в атрибуте `msDS-AllowedToDelegateTo`. Но атакующий с контролем над такой учёткой злоупотребляет механизмом [S4U2Self + S4U2Proxy](#): получает тикет от имени любого пользователя (включая Domain Admin) к разрешённому сервису. Бонус: альтернативные SPN в тикете можно подменить - если разрешено делегирование к `cifs/server`, меняем SPN на `ldap/server` и получаем доступ к LDAP. Microsoft это знает, но «it's by design».

Resource-Based Constrained Delegation - главный вектор

RBCD отличается тем, что конфигурация хранится не на делегирующей стороне, а на целевом компьютере в атрибуте `msDS-AllowedToActOnBehalfOfOtherIdentity`. Любой, кто может записать в этот атрибут, контролирует, кому разрешено имперсонировать пользователей к этому компьютеру. Звучит как баг, но нет - так задумано.

Цепочка атаки RBCD:

1. Атакующий имеет `WriteProperty` или `GenericAll` на целевой компьютер
2. Создаёт машинный аккаунт (по умолчанию любой доменный пользователь может создать до 10 штук - атрибут `[URL='https://learn.microsoft.com/en-us/windows/win32/adschema/a-ms-ds-machineaccountquota']ms-DS-MachineAccountQuota[/URL])`
3. Записывает SID созданного аккаунта в `msDS-AllowedToActOnBehalfOfOtherIdentity` целевого компьютера
4. Через `S4U2Self` + `S4U2Proxy` получает тикет от имени `Domain Admin` к целевому сервису

На Linux - связка `addcomputer.py` → `rbcd.py` → `getST.py`. На Windows - `PowerView` для создания аккаунта и записи атрибута, `Rubeus` для `S4U`-запросов. Весь процесс - минут пять, если знаешь что делать.

Практическая цепочка: от WriteDACL до DCSync за четыре шага

Полная цепочка, которую я использовал на реальных проектах. Допустим, `BloodHound` показал, что скомпрометированный пользователь `svc-monitor` имеет `WriteDACL` на объект домена `CONTOSO.LOCAL`.

Шаг 1: добавление ACE с правами репликации. Через `PowerView`: `Add-DomainObjectAcl -TargetIdentity "DC=contoso,DC=local" -PrincipalIdentity svc-monitor -Rights DCSync`. Команда добавляет два ACE: `DS-Replication-Get-Changes` и [DS-Replication-Get-Changes-All](#). С Linux то же самое делает `dacledit.py` из `Impacket` с параметрами `--action write --rights DCSync --principal svc-monitor`.

Шаг 2: DCSync. Теперь `svc-monitor` может запросить репликацию у контроллера домена. Через `secretsdump.py` с ключом `-just-dc-ntlm` вытягиваем NTLM-хеши всех учёток домена, включая `krbtgt`.

Шаг 3: Golden Ticket (при необходимости). Хеш krbtgt позволяет генерировать Golden Ticket (T1558.001, Credential Access) с произвольным SID и сроком действия. Но на практике после DCSync обычно хватает [pass-the-hash с хешем Domain Admin](#).

Шаг 4: очистка. Удаляем добавленные ACE - Remove-DomainObjectAcl с теми же параметрами. Это и OPSEC, и профессиональная этика: оставляй домен в том состоянии, в котором нашёл. Не надо дарить реальному злоумышленнику готовый путь.

Альтернативная цепочка через GenericAll на пользователя: сброс пароля целевой учётки через Set-DomainUserPassword, аутентификация под новыми credentials, lateral movement на хост, где эта учётка - локальный администратор. На Linux - net rpc password или impacket-changepasswd для сброса без знания текущего пароля.

LDAP Relay и ACL-атаки: комбинированный вектор

Отдельная история - комбинация NTLM relay с ACL-эксплуатацией (Praetorian детально это описывает). Атакующий принуждает жертву к NTLM-аутентификации на контролируемый хост (через IWA - Integrated Windows Authentication, где любой URL без точек классифицируется как Intranet-сайт), затем релеит аутентификацию на LDAP контроллера домена.

Через интерактивный LDAP-shell в NTLMRelayX атакующий действует от имени жертвы: сбрасывает пароли (если у жертвы есть ForceChangePassword), добавляет RBCD (если есть WriteProperty на компьютер), вписывает себя в группу (если есть ModifyGroupMembership). Этот вектор особенно неприятен тем, что организации, внедрившие SMB Signing, часто забывают про LDAP Signing - а без него relay на LDAP работает штатно. Типичная история: одну дверь заколотили, а соседнюю оставили нараспашку.

Ключевая деталь: для relay на LDAP нужно, чтобы жертва аутентифицировалась по HTTP, а не по SMB. Методы принуждения к HTTP-аутентификации - подмена DNS-записей через ADIDNS (любой доменный пользователь может создать запись, если она не существует) и эксплуатация WebDAV.

Обнаружение и защита: что должен знать пентестер

Понимание детекции - часть OPSEC. Ключевые события Windows Security Log:

- **Event ID 5136** - изменение атрибута объекта AD. Срабатывает при модификации DACL, записи в `msDS-AllowedToActOnBehalfOfOtherIdentity` и других атрибутов. Основной источник для детекции ACL-атак.
- **Event ID 4662** - операция с объектом. Фиксирует обращение к правам репликации (GUID {1131f6aa-9c07-11d1-f79f-00c04fc2dcd2} для DS-Replication-Get-Changes-All). Именно по нему SOC ловит DCSync.
- **Event ID 4724/4723** - сброс или изменение пароля. Срабатывает при ForceChangePassword.

Tiered delegation model (Tier-0 для DC, Tier-1 для серверов, Tier-2 для рабочих станций), описанный Semperis, - рабочая защита, но на практике его внедряют единицы. Для пентестера это значит: в большинстве доменов ACL-пути существуют, вопрос только в длине цепочки.

Защитные рекомендации для отчёта:

- Регулярный аудит ACL через BloodHound или PingCastle с фокусом на нестандартные ACE для непривилегированных принципалов
- Установка `ms-DS-MachineAccountQuota` в 0 - отрезает создание машинных аккаунтов и ломает стандартный RBCD-путь
- Включение LDAP Signing и Channel Binding на контроллерах домена
- Мониторинг Event ID 5136 на изменения DACL критичных объектов
- Настройка SIEM-правил на Windows File and Directory Permissions Modification (T1222.001, Defense Evasion) как сценария детекции

Вопрос к читателям

При RBCD-атаке ключевой prerequisite - возможность создать машинный аккаунт в домене (`ms-DS-MachineAccountQuota > 0`). Если квота выставлена в 0, стандартный путь через `addcomputer.py` или `New-MachineAccount` отрезан. Кто сталкивался с такой ситуацией на engagement? Какой альтернативный вектор использовали - компрометация существующего машинного аккаунта через его NTLM-хеш из LSA, или что-то другое? Поделитесь конкретной связкой инструментов и параметров, которая сработала при `MachineAccountQuota=0`.

Последнее редактирование: